UNIT 4 · TOPIC 4.1

Device and Endpoint Vulnerabilities

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A security team investigates an internet-connected tractor after its autopilot begins moving to unauthorized GPS coordinates. Forensic review reveals hidden software that silently collects location data and transmits it to an external server at regular intervals. Which type of malware best describes this threat?

○ A. Ransomware, because the software is encrypting the GPS configuration files.

○ B. Worm, because the software replicates itself across other devices on the farm network.

● **C. Spyware, because the software covertly collects and exfiltrates data without the user's knowledge.**

○ D. Logic bomb, because the software activates only when a specific condition is met.

Correct answer: C

Why: Spyware is malware designed to covertly monitor and exfiltrate data, here, GPS telemetry, without user awareness or consent. Ransomware encrypts data for extortion; a worm self-replicates across a network; a logic bomb triggers on a specific condition (e.g., a date or event) rather than running continuously. Only spyware matches the persistent, silent data-collection behavior described.

*Why the others are wrong: **A**, Ransomware requires an encryption and ransom-demand component, neither of which is present here. **B**, No evidence of self-replication to other devices is given; the software only phones home. **D**, Logic bombs are dormant until triggered; the described software runs continuously.*

2. An automated milking machine's onboard computer is observed making periodic outbound connections to a cluster of unfamiliar IP addresses, transmitting small data packets at regular intervals even when idle. No legitimate application accounts for this traffic. Which malware classification most accurately describes this behavior?

○ A. Rootkit, because the malware is hiding system files from administrators.

● **B. Bot, because the device appears to be under remote command-and-control as part of a botnet.**

○ C. Trojan, because the malware disguised itself as legitimate firmware to be installed.

○ D. Adware, because the device is generating unsolicited network traffic.

Correct answer: B

Why: A bot (botnet node) is a compromised device controlled remotely by a command-and-control server, exhibiting periodic beacon traffic to C2 infrastructure, exactly what is described. A rootkit hides malicious activity rather than generating periodic C2 traffic. A trojan is defined by its deceptive delivery method, not its ongoing behavior. Adware generates advertising-related traffic, not command-and-control beacons.

*Why the others are wrong: **A**, Rootkit behavior centers on hiding processes/files; the scenario describes active outbound C2 traffic, not concealment. **C**, Trojan describes how malware was delivered, not what it does afterward; the scenario focuses on runtime behavior. **D**, Adware produces advertising popups or redirects, not structured periodic packets to remote IPs.*

3. Following a cyberattack, an irrigation controller's stored configuration files are encrypted and access is blocked. A message appears on the management dashboard reading: "Your device data has been locked. Send 0.5 BTC to [address] within 72 hours to recover your files." Which malware type was used in this attack?

○ A. Spyware, because the attacker is collecting information from the device.

○ B. Backdoor, because the attacker established persistent unauthorized access to the device.

○ C. Keylogger, because the attacker captured keystrokes to obtain admin credentials.

● D. Ransomware, because the attacker has encrypted data and is demanding payment for its restoration.

Correct answer: D

Why: Ransomware encrypts a victim's data and demands payment (usually cryptocurrency) for the decryption key. All three defining elements are present: encryption of files, loss of access, and an explicit ransom demand. Spyware exfiltrates data quietly. A keylogger records keystrokes. A backdoor provides persistent access but does not inherently encrypt data or demand payment.

*Why the others are wrong: **A**, Spyware silently exfiltrates data; it does not encrypt files or issue ransom demands. **B**, A backdoor enables covert re-entry; the scenario describes data encryption and extortion, not persistent access alone. **C**, A keylogger is a credential-harvesting tool; no credential theft is indicated in the described outcome.*

4. A GPS-guided tractor's remote management interface is exposed to the internet and uses factory-default credentials (username: admin / password: admin) that were never changed after deployment. Which of the following most accurately explains how an adversary could exploit this vulnerability to cause disruption?

● A. The adversary logs directly into the management interface using the publicly documented default credentials, then alters GPS waypoints or installs malware, requiring no technical sophistication.

○ B. The adversary performs a brute-force dictionary attack requiring thousands of attempts before gaining access.

○ C. The adversary sends a phishing email to the farmer to harvest their personal banking credentials.

○ D. The adversary exploits a buffer overflow in the GPS satellite receiver firmware to inject arbitrary code.

Correct answer: A

Why: Default credentials are publicly known and require no exploitation technique beyond typing them in. This gives an adversary immediate authenticated access to the management interface, from which they can alter device behavior (e.g., redirect GPS routes, disable safety limits) or install persistent malware. This is classified as a zero-effort, high-impact vulnerability. Phishing targets humans, not device interfaces. Brute-force is unnecessary when the password is already known. A buffer overflow is a separate, more technical vulnerability not relevant to credential mismanagement.

*Why the others are wrong: **B**, Brute force is the method used when credentials are unknown; default credentials are already known publicly, making brute force redundant. **C**, Phishing is a social-engineering attack on people, not a direct exploitation of the device's management interface. **D**, A buffer overflow exploits memory management flaws, not authentication weaknesses; it is a different vulnerability class entirely.*

5. An agricultural-tech company's irrigation management systems use unencrypted HTTP for their web-based control interface, transmitting operator credentials and device commands in plaintext over the farm's Wi-Fi network. How can an adversary on the same network exploit this insecure configuration?

○ A. The adversary can overflow the irrigation controller's memory by sending a large number of HTTP packets simultaneously.

○ B. The adversary can install ransomware by sending a malicious email attachment to the farm operator.

● C. The adversary can perform a man-in-the-middle attack, intercepting and reading credentials and commands in plaintext, and potentially injecting their own commands.

○ D. The adversary can physically remove the controller's storage media while the system is running.

Correct answer: C

Why: Unencrypted HTTP transmits all data, including credentials and control commands, as readable plaintext. An adversary with access to the same network segment can use a

packet sniffer or ARP spoofing to position themselves as a man-in-the-middle, capturing credentials and, in more sophisticated attacks, injecting or modifying commands before they reach the device. HTTPS with TLS would prevent this by encrypting the channel. The other options describe different attack vectors unrelated to unencrypted HTTP.

*Why the others are wrong: **A**, A packet-volume attack describes a denial-of-service scenario, not an exploitation of unencrypted transmission. **B**, Phishing via email is a social-engineering vector independent of whether the web interface uses HTTP or HTTPS. **D**, Physical media theft is a physical-security attack, not a software or network-layer exploitation of HTTP.*

6. A connected tractor's embedded network stack runs firmware version 2.1.0, which contains a publicly disclosed buffer overflow vulnerability in the packet-parsing routine. A patch has been available for six months but was never applied. Which attack technique would an adversary most likely use to exploit this specific vulnerability?

● A. Sending a specially crafted network packet that overflows the input buffer, corrupting adjacent memory and allowing the adversary to execute arbitrary code.

○ B. Social engineering the farm operator by phone to reveal the device's admin password.

○ C. Performing an online brute-force attack against the tractor's web management login page.

○ D. Intercepting GPS satellite uplink signals to inject false positioning data.

Correct answer: A

Why: A buffer overflow is exploited by supplying more data than a buffer can hold, overwriting adjacent memory, including return addresses or function pointers, to redirect program execution to attacker-controlled code. This technique directly targets the described vulnerability in the packet-parsing routine. Social engineering exploits human trust, not memory management flaws. Brute-force targets authentication, not a memory corruption bug. GPS signal spoofing is a radio-frequency attack, not a firmware exploitation.

*Why the others are wrong: **B**, Social engineering bypasses the technical vulnerability entirely; the question specifies exploiting the buffer overflow flaw specifically. **C**, Brute-force attacks authentication credentials, a separate vulnerability class from a memory-corruption bug in packet parsing. **D**, GPS spoofing is a signal-layer attack; it does not interact with or exploit software-level buffer overflow vulnerabilities.*

7. A security engineer assesses three vulnerabilities in a fleet of internet-connected tractors: (1) Remote management interface accessible over the public internet using documented default credentials. (2) Firmware update packages transmitted over the network without cryptographic signing or integrity verification. (3) GPS telemetry data transmitted in plaintext over Wi-Fi. Using a likelihood × impact framework, which risk ranking is best supported?

○ A. GPS telemetry (highest) > firmware signing (medium) > default credentials (lowest), because GPS exposure directly threatens physical farm operations.

● B. Default credentials (highest) > firmware signing (medium) > GPS telemetry (lowest), because default credentials are trivially exploitable with maximum likelihood and grant full system control.

○ C. All three vulnerabilities are equally critical and must be addressed simultaneously before any ranking can be assigned.

○ D. Firmware signing (highest) > default credentials (medium) > GPS telemetry (lowest), because unsigned firmware affects every device update cycle regardless of credential policy.

Correct answer: B

Why: Risk = likelihood × impact. Default credentials score maximum likelihood (publicly known, no skill required, network-accessible) × maximum impact (authenticated admin access enables all further attacks, malware installation, GPS manipulation, or physical sabotage). Unsigned firmware has high impact (fleet-wide persistent compromise possible) but lower likelihood, an adversary must achieve a network position to intercept update traffic.

Plaintext GPS telemetry has medium confidentiality/integrity impact but does not by itself grant device control. Therefore B correctly orders the risks under a likelihood × impact model.

*Why the others are wrong: **A**, GPS telemetry exposure is a confidentiality risk but does not grant device control; it cannot rank above a vulnerability that enables complete system compromise. **C**, Risk frameworks explicitly exist to support prioritization; refusing to rank is not a valid risk management outcome and is not consistent with NIST or similar guidance. **D**, Unsigned firmware requires a man-in-the-middle position to exploit (lower likelihood than typing known default credentials); D underestimates how trivially exploitable default credentials are.*

8. A security engineer documents a risk for internet-connected milking machines running embedded Linux firmware with 12 unpatched CVEs, three of which are rated 9.0–9.8 CVSS and allow unauthenticated remote code execution over the public internet. Which risk assessment conclusion is most accurate?

● A. Risk level: Critical. Three unauthenticated RCE vulnerabilities with CVSS scores above 9.0 represent near-certain exploitability and the potential for full device compromise, physical damage, and safety violations.

○ B. Risk level: Low. The machines are in a private barn environment and are unlikely targets for sophisticated adversaries.

○ C. Risk level: Medium. CVSS scores reflect theoretical severity and actual exploitability in the field is typically much lower than the base score suggests.

○ D. Risk level: High, but acceptable because patching embedded operational technology mid-season is operationally disruptive and the risk is offset by physical isolation.

Correct answer: A

Why: CVSS 9.0+ unauthenticated RCE vulnerabilities on internet-exposed operational technology are by definition Critical under every major risk framework (NIST, CVSS v3.1 qualitative scale). "Private barn" does not mean network-isolated if the devices are internet-connected; physical location does not reduce network attack surface. CVSS base scores for RCE at 9.0+ consistently correspond to high real-world exploitation rates (EPSS data corroborates this). "Acceptable" risk cannot be determined by operational convenience alone without compensating controls, and none are mentioned. B is the only conclusion consistent with the evidence.

*Why the others are wrong: **B**, Physical location is irrelevant for internet-connected devices; network attack surface is determined by reachability, not geography. **C**, While CVSS base scores can overstate exploitability in some cases, unauthenticated RCE CVEs at 9.0+ have historically high real-world exploitation rates; "medium" understates the risk. **D**, Operational disruption of patching is a cost consideration, not a risk mitigant; without compensating controls, accepting critical risk due to scheduling inconvenience is not defensible risk management.*

9. An adversary exploited default credentials on 40 irrigation controllers, installed spyware, and exfiltrated six months of crop-planning, scheduling, and chemical-application data. The devices remain operational but are fully compromised. Using a likelihood × impact risk documentation framework, which post-incident entry is most complete and accurate?

○ A. Threat: External. Likelihood: Low (attack required sophisticated knowledge of agricultural systems). Impact: Low (only data was accessed; equipment remains operational). Risk: Low.

● B. Threat: External. Likelihood: High (default credentials are trivially exploitable and publicly known). Impact: High (sensitive operational data exfiltrated; persistent compromise enables follow-on sabotage; regulatory notification may be required). Risk: Critical.

○ C. Threat: Internal. Likelihood: Medium. Impact: Medium. Risk: Medium. Attacker required local access to install spyware on the controllers.

○ D. Threat: External. Likelihood: High. Impact: Low (data breach only; no physical disruption occurred). Risk: Medium.

Correct answer: B

Why: Default credentials make likelihood objectively high, no skill is required and they are publicly documented. Impact is high across multiple dimensions: confidentiality breach (crop data with commercial value and potential for competitive harm), integrity risk (persistent spyware means device behavior cannot be trusted), and availability risk (a follow-on destructive payload could disable the fleet). Regulatory data-breach notification requirements may apply depending on jurisdiction. "Devices remain operational" does not reduce impact, persistent compromise means the adversary retains ongoing access. A underestimates both dimensions. C misidentifies the threat as internal with no basis. D correctly identifies high likelihood but incorrectly labels impact as low by ignoring persistence, trust loss, and potential for escalation.

*Why the others are wrong: **A**, Default credentials are the lowest-skill exploit class; likelihood cannot be rated Low. Equipment being operational while persistently compromised is not a low-impact outcome. **C**, The attack was conducted remotely over the internet via default credentials; no physical/local access was required, disqualifying an "internal" threat classification. **D**, Impact cannot be rated Low when persistent spyware remains installed and operational, the adversary retains ongoing access and the ability to escalate to destructive attacks at any time.*

10. Which of the following best describes an Internet of Things (IoT) device?

○ A. A high-performance server in a data center running a virtualization hypervisor to host multiple virtual machines.

○ B. A dedicated hardware firewall appliance managing inbound and outbound enterprise network traffic.

○ C. A standard desktop computer running a general-purpose operating system with user productivity applications.

● D. A network-connected physical device with embedded sensors or actuators designed to interact with or monitor the physical world.

Correct answer: D

Why: IoT devices are purpose-built networked devices that interact with the physical environment through sensors (collecting data like temperature, location, or motion) or actuators (controlling physical systems like motors, valves, or locks). They typically run lightweight embedded operating systems rather than full general-purpose OSes. Servers, desktops, and dedicated firewalls are conventional computing devices that do not fit the IoT definition, even if networked.

*Why the others are wrong: **A**, Servers are general-purpose computing infrastructure; they do not interact with the physical world through sensors or actuators. **B**, A hardware firewall is a network security appliance, not an IoT device, it does not sense or actuate physical phenomena. **C**, A general-purpose desktop with productivity software is the opposite of a constrained, purpose-built IoT device.*

11. A GPS-guided tractor's onboard computer is designed to run a single real-time control program, accepts sensor input from GPS and proximity sensors, and has 512 MB of RAM. It cannot be easily reconfigured to run general applications. Which computing device category does this best represent?

○ A. General-purpose personal computer (PC)

○ B. Mainframe terminal

○ C. Thin client

● D. Embedded system / Industrial IoT (IIoT) device

Correct answer: D

Why: An embedded system is a computing device built into a larger machine to perform a specific control function. Industrial IoT (IIoT) devices are embedded systems connected to a network. The described tractor computer matches this exactly: single purpose (tractor control), constrained resources, and physical sensor integration. A general-purpose PC is configurable for many tasks. A mainframe terminal is a legacy thin client for mainframe access. A thin client streams its workload to a remote server rather than running local real-time control.

*Why the others are wrong: **A**, A general-purpose PC is designed to run many types of user applications and is not purpose-built for control tasks; the tractor computer explicitly cannot be reconfigured. **B**, A mainframe terminal is a network-connected input/output device for a mainframe host; it does not run local real-time control software. **C**, A thin client relies on a server for compute; the tractor's onboard computer runs its control program locally in real time.*

12. Which of the following is NOT a typical characteristic of IoT and embedded devices compared to standard general-purpose computers?

○ A. Constrained processing power and limited RAM

○ B. Designed to perform a specific, narrow set of tasks

○ C. Often connected to a network or the internet

● D. Runs a full general-purpose operating system with a wide range of user-installable applications

Correct answer: D

Why: IoT and embedded devices typically run stripped-down, real-time, or custom operating systems (e.g., FreeRTOS, VxWorks, custom Linux builds) optimized for their specific task, not general-purpose OSes like Windows or macOS that support arbitrary user-installed applications. The other options accurately describe IoT devices: constrained resources, purpose-specific design, and network connectivity are defining characteristics.

*Why the others are wrong: **A**, Constrained resources are a defining IoT/embedded characteristic, these devices are optimized for cost and power, not raw compute. **B**, Purpose-specificity is the most fundamental characteristic of an embedded system by definition. **C**, Network connectivity (especially internet connectivity) is what distinguishes IoT from older embedded systems and is central to both their utility and their attack surface.*

13. A fleet of connected tractors runs firmware version 2.1.0, which contains an unpatched privilege escalation vulnerability. A patch has been available for eight months. Which statement best explains why privilege escalation is a particularly severe risk in an operational technology (OT) context such as internet-connected farm equipment?

● A. Privilege escalation lets an adversary elevate a low-privileged foothold to full system control, enabling them to modify control logic, disable safety interlocks, or install persistent malware, potentially causing physical damage.

○ B. Privilege escalation allows an adversary to create additional user accounts, which is time-consuming to remediate but does not affect device operation.

○ C. Privilege escalation is only relevant on multi-user systems and does not apply to single-purpose OT devices.

○ D. Privilege escalation primarily affects data confidentiality and has minimal impact on device availability or physical-world integrity.

Correct answer: A

Why: In OT and IIoT environments, control over a device's operating system translates directly to control over physical actuators, motors, hydraulics, GPS steering, and safety cutoffs. Privilege escalation is the mechanism by which an adversary moves from a limited entry point to this level of control. Unlike IT environments where the impact is usually data-centric, OT privilege escalation can cause physical harm (equipment damage, crop destruction, or safety incidents). Even single-purpose devices run processes with varying privilege levels, making C incorrect.

*Why the others are wrong: **B**, Creating extra user accounts is a minor housekeeping issue; it dramatically understates what full privilege escalation enables in an OT context. **C**, All computing processes run under some privilege model; single-purpose devices still have kernel vs. user space distinctions that privilege escalation exploits. **D**, In OT, the most critical impact of privilege escalation is on availability and physical integrity (not confidentiality), making this answer the inverse of reality.*

14. An agricultural-tech company's milking machine management software includes a diagnostic interface that allows technicians to run system checks. The interface passes user-supplied

input directly to the underlying operating system shell without sanitization or input validation. How could an adversary exploit this insecure configuration?

- **● A. By injecting operating system commands through the diagnostic interface input field to execute arbitrary code with the application's privilege level.**
- ○ B. By sending phishing emails to farm employees to obtain their VPN credentials and then connecting remotely.
- ○ C. By intercepting firmware update packages in transit and substituting them with malicious versions.
- ○ D. By flooding the diagnostic interface with requests to cause a denial-of-service condition.

Correct answer: A

Why: When user input is passed unsanitized to an OS shell, an adversary can append shell metacharacters (e.g., semicolons, pipes, backticks) to inject arbitrary commands, a class of vulnerability known as OS command injection. This gives the attacker code execution at the privilege level of the application process, without needing valid credentials or a separate malware delivery mechanism. The other options describe different attack vectors (phishing, supply-chain firmware tampering, DoS) that exploit different vulnerabilities, not the unsanitized input described.

*Why the others are wrong: **B**, Phishing is a social-engineering attack independent of the diagnostic interface vulnerability; it does not exploit unsanitized input. **C**, Firmware interception is a supply-chain attack; it exploits the absence of cryptographic signing, not a command injection flaw in the diagnostic interface. **D**, Flooding causes availability impact but does not achieve code execution or data access, which are the primary consequences of command injection.*

15. Connected irrigation controllers in a farm network share a network VLAN with the farm's office computers. An adversary who has already compromised one office workstation can reach and send commands to any irrigation controller directly, with no additional credentials required. Which device vulnerability does this scenario most clearly illustrate?

- **● A. Insecure network segmentation, enabling lateral movement from the IT (office) environment into the OT (control) environment.**
- ○ B. Weak authentication on the irrigation controllers allowing unauthenticated command execution.
- ○ C. Unencrypted data transmission on the irrigation controller management interface.
- ○ D. Absence of physical locks on office workstations, allowing unauthorized physical access.

Correct answer: A

Why: Network segmentation separates environments with different trust levels, in this case, the office IT network and the operational technology control network, so that a compromise in one cannot directly reach the other. Placing both on the same VLAN removes this boundary, enabling lateral movement: an adversary with a foothold on one office machine can pivot to OT devices without additional authentication or network traversal. This is the specific configuration flaw at issue. Weak authentication (B) and unencrypted comms (C) may also exist but are not what the scenario specifically illustrates. Physical access (D) is not relevant here.

*Why the others are wrong: **B**, Weak authentication is a possible secondary vulnerability, but the scenario's root cause is network reachability, the adversary can reach the controllers at all, which should not be possible from the office VLAN. **C**, Unencrypted comms are a separate vulnerability class (confidentiality/integrity); the scenario describes unauthorized network reachability, not traffic interception. **D**, Physical security of workstations is unrelated to a network segmentation flaw that allows lateral movement between logical network segments.*

16. A security engineer is completing a risk register entry for a fleet of 40 internet-connected GPS-guided tractors. The tractors run firmware v2.1.0, which has a publicly disclosed RCE vulnerability (CVE available, proof-of-concept exploit code published). A patch has been available for six months and was never deployed. Which risk register entry is most complete and professionally accurate?

○ A. Risk ID: R-04 | Asset: Tractor fleet | Threat: Cyberattack | Vulnerability: Old firmware | Likelihood: Possible | Impact: Significant | Risk Level: High | Recommendation: Update firmware when convenient.

○ B. Risk ID: R-04 | Asset: Tractors | Threat: Hackers | Vulnerability: Software bugs | Likelihood: Unknown | Impact: Unknown | Risk Level: Medium | Recommendation: Annual review.

○ C. Risk ID: R-04 | Asset: Firmware version | Threat: Malware | Likelihood: Low | Impact: Medium | Risk Level: Low | Recommendation: Monitor the situation.

● D. Risk ID: R-04 | Asset: Tractor fleet (40 units, field-deployed) | Threat: Remote adversary exploiting published RCE CVE via network | Vulnerability: Firmware v2.1.0, unpatched 6 months post-disclosure, public PoC available | Likelihood: High (public PoC lowers exploit barrier to script-kiddie level) | Impact: Critical (full device control; physical damage, crop loss, and safety incidents possible) | Risk Level: Critical | Recommendation: Emergency patching within 30 days; interim control: restrict management interfaces to internal VLAN and disable public internet exposure immediately.

Correct answer: D

Why: A professional risk register entry must identify the specific asset with quantity, name the threat actor and attack vector precisely, describe the vulnerability with version and patch status, rate likelihood and impact with justification, assign a composite risk level, and recommend both immediate compensating controls and a remediation timeline. B does all of this. A is vague (no quantity, no patch status, no interim control, "when convenient" is not risk-appropriate for a Critical finding). C and D contain almost no usable information and would not support any remediation decision.

*Why the others are wrong: **A**, While structurally closer to a real entry than C or D, A fails on specificity: no unit count, no patch lag duration, no PoC mention, no interim control, and "when convenient" grossly understates urgency for a Critical-rated risk. **B**, Likelihood: Unknown and Impact: Unknown in a risk register are not acceptable outcomes, the engineer's job is to determine these values; leaving them unknown means the assessment was not performed. **C**, Rating a publicly-disclosed RCE with available PoC as Low likelihood is factually indefensible; "monitor" is not a remediation action.*

17. A security engineer must present device vulnerability risks to executive leadership at an agricultural-tech firm. Format 1 is a technical CVE list with CVSS vector strings, exploit complexity ratings, and CWE classifications. Format 2 maps each vulnerability to business impact (crop loss, equipment damage, regulatory fine risk, reputational harm), with likelihood ratings and specific recommended mitigations. Which format best fulfills the objective of "document risks from device vulnerabilities" for a non-technical decision-making audience?

○ A. Format 1 only, because technical precision is always superior in security risk documentation and executives should learn to read CVE data.

○ B. Both formats are equivalent; the choice is purely a matter of personal preference.

○ C. Neither format, risk documentation should only be delivered verbally to avoid creating discoverable evidence in the event of litigation.

● D. Format 2 only, because documenting risk for decision-makers requires translating technical findings into business impact, likelihood, and actionable recommendations, which is exactly what risk documentation is for.

Correct answer: D

Why: Risk documentation serves its audience. For executive decision-makers, who allocate budgets, approve remediation timelines, and are accountable for risk acceptance, the relevant output is business impact, likelihood, and prioritized recommendations, not CVSS vector strings. Format 2 directly supports decision-making. Format 1 is valuable for technical teams implementing mitigations but does not communicate actionable risk to a non-technical audience. C is legally incorrect (written risk documentation is standard practice and expected by regulators and insurers). D is false, the formats serve fundamentally different communication purposes.

*Why the others are wrong: **A**, CVSS vector strings and CWE codes require cybersecurity training to interpret; presenting them to non-technical executives without translation fails the communication objective. **B**, The formats are not equivalent, one communicates to technical implementers, the other to business decision-makers; they serve different but complementary purposes. **C**, Avoiding written documentation to prevent legal discovery is bad-faith risk management practice and typically inadmissible as a defense; regulators and cyber insurers require written risk records.*

18. After completing a device vulnerability assessment, a security engineer documents two risks:
Risk A, default credentials on 40 tractors' management interfaces (rated Critical); remediation cost: $500 and 1 hour per device ($20,000 total, completable in one week).
Risk B, unencrypted GPS telemetry (rated High); remediation cost: $200,000 firmware redesign, estimated 9-month timeline.
How should cost and effort information be incorporated into the risk register, and what remediation priority order follows?

● A. Include remediation cost and timeline in the risk register alongside risk level, enabling stakeholders to identify that Risk A (Critical, low cost, fast) should be addressed immediately while Risk B (High, high cost, long timeline) is planned and tracked separately. Prioritize Risk A first.

○ B. Do not include cost in the risk register; remediation cost is a business decision outside the scope of risk documentation. Prioritize by risk rating alone: Risk A first.

○ C. Prioritize Risk B first, because the larger investment signals that it is the more serious problem.

○ D. Mark both risks as acceptable until budget is available, since neither can be remediated without organizational approval.

Correct answer: A

Why: Risk documentation is most useful when it includes not only risk severity but also remediation effort and cost, enabling stakeholders to make informed prioritization decisions. Incorporating cost reveals that Risk A, despite being the highest-severity finding, is also the cheapest and fastest to fix ($500 per device, one week to complete), making it the clear first priority: high risk reduction per dollar spent. Risk B requires a multi-month engineering project and should be tracked in the risk register with a formal remediation plan and interim compensating controls. Including cost does not remove the risk register's core function; it enhances it. Remediation cost cannot be excluded from a complete risk register entry under any standard risk management framework.

*Why the others are wrong: **B**, Risk registers in all major frameworks (NIST SP 800-30, ISO 27005) explicitly include remediation cost and effort as components; excluding them produces an incomplete and less actionable document. **C**, Remediation cost is not a proxy for risk severity; a vulnerability can be cheap to fix and extremely severe, or expensive to fix and moderate in severity. Cost reflects engineering complexity, not risk impact. **D**, Accepting Critical risk without a documented compensating control or a formal risk-acceptance decision by appropriate authority is not a valid risk management posture; it represents an undocumented gap.*